

SOC/L1 - 7.5. IDS Fundamentals

IDS Fundamentals

Task 1 - What Is an IDS

Intrusion Detection System (IDS): An IDS is a security solution deployed inside a network to monitor traffic and detect suspicious or malicious activities that may bypass the firewall. While firewalls control incoming and outgoing connections, IDS identifies threats that occur after a connection is established.

How IDS Works: IDS monitors network activity using **signature-based detection** (known attack patterns) and **anomaly-based detection** (unusual behavior). When suspicious activity is detected, it generates alerts for security administrators but does not automatically block or stop the threat.

- **Firewall vs IDS:**
 - **Firewall:** Acts as the first line of defense by filtering and allowing/denying network connections based on predefined rules.
 - **IDS:** Acts as a monitoring system that detects malicious behavior inside the network after traffic passes through the firewall.
- **Purpose of IDS:** IDS helps security teams quickly identify potential attacks, investigate suspicious activity, and respond to threats within the network.

Answer the questions below

Can an intrusion detection system (IDS) prevent the threat after it detects it?
Nay

Task 2 - Types of IDS

IDS can be deployed in the following ways:

- **Host Intrusion Detection System (HIDS):** HIDS is installed on individual devices to monitor and detect suspicious activities on a specific host. It

provides detailed visibility into system events, files, and user activities. However, managing HIDS can be difficult in large environments because each host requires separate deployment and maintenance.

- **Network Intrusion Detection System (NIDS):** NIDS monitors network traffic across multiple devices to detect malicious activities affecting the entire network. It provides a centralized view of security events and helps security teams identify threats without installing software on every individual host.
- **HIDS vs NIDS:**
 - **HIDS:** Focuses on monitoring a single device.
 - **NIDS:** Focuses on monitoring network-wide traffic and multiple systems.

Detection Modes

- **Signature-Based IDS:** Signature-based IDS detects threats by comparing network or system activity against a database of known attack patterns (signatures). It is effective at identifying previously known attacks quickly but cannot detect **zero-day attacks** because they do not have existing signatures.
- **Anomaly-Based IDS:** Anomaly-based IDS learns the normal behavior (baseline) of a system or network and detects activities that deviate from this behavior. It can identify unknown and zero-day attacks but may generate more **false positives** because legitimate activities can sometimes appear unusual. Proper tuning can help reduce false alerts.
- **Hybrid IDS:** Hybrid IDS combines both signature-based and anomaly-based detection methods. It uses signatures to detect known threats and anomaly detection to identify new or unknown attacks, providing broader security coverage.
- **Choosing an IDS Type:** Signature-based IDS provides fast detection for known threats and is useful for smaller threat environments. Anomaly-based and hybrid IDS solutions are better suited for detecting modern threats, including zero-day attacks, but may require more processing power and tuning.

Answer the questions below

Which type of IDS is deployed to detect threats throughout the network?
Network Intrusion Detection System

Which IDS leverages both signature-based and anomaly-based detection techniques? Hybrid IDS

Task 3 - IDS Example: Snort

- **Snort:** Snort is a widely used open-source IDS tool developed in 1998. It uses **signature-based** and **anomaly-based** detection methods to identify malicious network activity.
- **Snort Rules:** Snort relies on rule files that contain patterns of known attacks. It includes built-in rules that can detect many types of malicious traffic, but users can also create custom rules to identify specific threats.
- **Customisation:** Administrators can modify Snort by adding new detection rules, disabling unnecessary built-in rules, and creating custom rules based on their network security requirements. This flexibility allows Snort to detect targeted attacks and specific network behaviors.

Modes of Snort

Mode	Description	Use Case
Packet sniffer mode	This mode reads and displays network packets without performing any analysis on them. The packet sniffer mode of Snort does not directly relate to IDS capabilities, but it can be helpful in network monitoring and troubleshooting. In some cases, system administrators might need to read the traffic flow without performing any detection to diagnose specific issues. In this case, they can utilize the packet sniffer mode of Snort. This mode allows you to display the network traffic on the console or even output it in a file.	The network team observes some network performance issues. To diagnose the issue, they need detailed insights into the network traffic. For this purpose, they can utilize Snort's packet sniffer mode.

Mode	Description	Use Case
Packet logging mode	Snort performs detection on the network traffic in real-time and displays the detections as alerts on the console for the security administrators to take action. However, in some cases, the network traffic needs to be logged for later analysis. The packet logging mode of Snort allows you to log the network traffic as a PCAP (standard packet capture format) file. This includes all the network traffic and any detections from it. Forensic investigators can use these Snort log files to perform the root cause analysis of previous attacks.	The security team needs to initiate a forensic investigation of a network attack. They would need the traffic logs to perform the root cause analysis. The network traffic logged through Snort's packet logging mode can help them.
Network Intrusion Detection System mode	Snort's NIDS mode is the primary mode that monitors network traffic in real-time and applies its rule files to identify any match to the known attack patterns stored as signatures. If there is a match, it generates an alert. This mode provides the main functionality of an IDS solution.	The security team must proactively monitor their network or systems to detect potential threats. They can leverage Snort's NIDS mode to achieve this.

Answer the questions below

Which mode of Snort helps us to log the network traffic in a PCAP file? Packet Logging Mode

What is the primary mode of Snort called? Network Intrusion Detection System Mode

Task 4 - Snort Usage

- **Snort Configuration:** During installation, Snort requires the network interface and IP range to monitor. By default, Snort captures only traffic directed to the host, but **promiscuous mode** allows it to monitor traffic across the entire network.

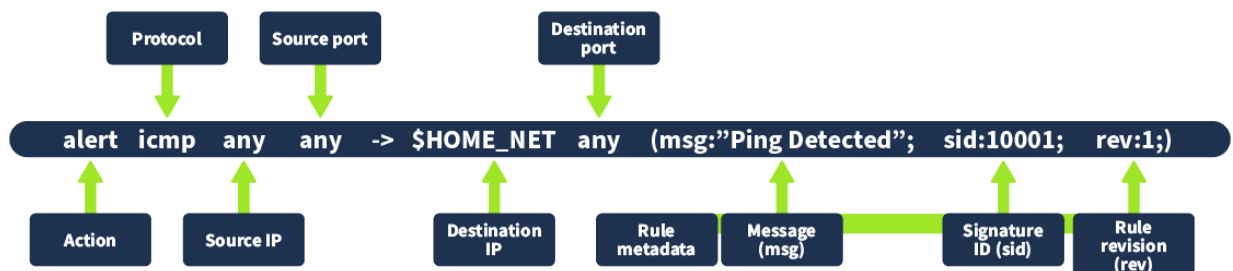
- **Snort Files and Directories:** Snort stores its configuration files, rules, and other resources in a main directory such as `/etc/snort` or `/usr/local/etc/snort` depending on the installation method.
- **Snort Configuration File:** The main configuration file is `snort.lua`, which defines important settings such as enabled rule files, monitored network ranges, and detection options. The configuration file is loaded using the `c` option.
- **Rule Files:** Snort detection rules are stored in the `rules` directory. These rules define patterns and behaviors that Snort uses to identify suspicious or malicious traffic.

Snort Directory

```
ubuntu@tryhackme:~$ ls /etc/snort
Intro_to_IDS.pcap      community-sid-msg.map  reference.conf
g snort.conf           snort.lua             unicode.map
classification.config  gen-msg.map           rules
snort.debian.conf     threshold.conf
```

Rule Format

- **Snort Rule Format:** Snort rules follow a specific structure to define what type of traffic should be detected and what action should be taken.
- A rule can specify details such as the **protocol** (e.g., ICMP), **source and destination IP addresses**, **ports**, and the **network range** to monitor.
- When matching traffic is detected, Snort triggers an alert with a defined message, such as **"Ping Detected"**, allowing security teams to investigate suspicious activity.



The details of the components involved in this rule are given below:

- **Action:** This specifies which action to take when the rule triggers. In this case, we have the action to "alert" when the traffic matches this rule.
- **Protocol:** This refers to the protocol that matches this rule. In this case, we use the protocol "ICMP" when pinging a host.
- **Source IP:** This determines the IP originating from the traffic. Since we want to detect traffic from any source IP, we set this as "any".
- **Source port:** This determines the port from which the traffic originates. Since we want to detect traffic from any source port, we set this as "any".
- **Destination IP:** This specifies the destination IP to which the matching traffic comes; it generates the alert. In this case, we used "\$HOME_NET". This is a variable, and we defined its value as our whole network's range in Snort's configuration file.
- **Destination port:** This specifies the port the traffic would reach. Since we want to detect traffic coming to any port, we set it to "any."
- **Rule metadata:** Every rule has some metadata. That is defined at the end of the rule in parentheses. The following are its components:
 - **Message (msg):** This describes the message displayed when the subject rule triggers. The message should indicate the type of activity detected. In this case, we used "Ping Detected".
 - **Signature ID (sid):** Every rule has a unique identifier that differentiates it from others. This identifier is called the signature ID (sid). In this case, we set the sid to "10001".
 - **Rule revision (rev):** This sets the rule's revision number. Every time the rule is modified, its revision number is incremented, which helps in tracking changes to any rule.

Rule Creation

```
ubuntu@tryhackme:~$ sudo nano /etc/snort/rules/local.rules
```

Rule Testing

```
ubuntu@tryhackme:~$ sudo snort -q -l /var/log/snort -i lo -A  
alert_fast -c /etc/snort/snort.lua
```

Ping Host

```
ubuntu@tryhackme:~$ ping 127.0.0.1
```

Running Snort for Detections

```
ubuntu@tryhackme:~$ sudo snort -q -l /var/log/snort -i lo -A  
alert_fast -c /etc/snort/snort.lua  
07/24-10:46:52.401504  [**] [1:1000001:1] "Loopback Ping Dete  
cted" [**] [Priority: 0] {ICMP} 127.0.0.1 -> 127.0.0.1  
07/24-10:46:53.406552  [**] [1:1000001:1] "Loopback Ping Dete  
cted" [**] [Priority: 0] {ICMP} 127.0.0.1 -> 127.0.0.1  
07/24-10:46:54.410544  [**] [1:1000001:1] "Loopback Ping Dete  
cted" [**] [Priority: 0] {ICMP} 127.0.0.1 -> 127.0.0.1
```

Running Snort on PCAP Files

```
ubuntu@tryhackme:~$ sudo snort -q -l /var/log/snort -r Task.p  
cap -A alert_fast -c /etc/snort/snort.lua
```

Answer the questions below

- | Where is the main directory of Snort that stores its files? /etc/snort
- | Which field in the Snort rule indicates the revision number of the rule? rev
- | Which protocol is defined in the sample rule created in the task? icmp
- | What is the file name that contains custom rules for Snort? local.rules

Task 5 - Practical Lab

Scenario: You are a third-party forensic investigator. A company contacts you to investigate a recent attack on their network. They handed over a PCAP file named "Intro_to_IDS.pcap", which contained the network traffic captured during the attack. Your task is to run Snort on this PCAP file and answer the questions given in this task.

Note: The PCAP file `Intro_to_IDS.pcap` is placed in the `/etc/snort/` directory. You have to change your directory to `/etc/snort` and run the PCAP analysis command on that new PCAP file the same way as we did in task 4.

Answer the questions below

What is the IP address of the machine that tried to connect to the subject machine using SSH? 10.11.90.211

```
classification.config  rules                      unicode.map
community-sid-msg.map  snort.conf
gen-msg.map            snort.debian.conf
ubuntu@tryhackme:/etc/snort$ sudo snort -q -l /var/log/snort -r Intro_to_IDS.pcap -A console -c /etc/snort/snort.conf
07/18-12:52:59.337559  [**] [1:1000002:1] SSH Connection Detected [**]
[Priority: 0] {TCP} 10.11.90.211:54334 -> 10.10.161.151:22
```

ubuntu@tryhackme:~\$ sudo snort -q -l /var/log/snort -r Intro_to_IDS.pcap -A console -c /etc/snort/snort.conf

What other rule message besides the SSH message is detected in the PCAP file? Ping Detected

```
[Priority: 0] {TCP} 10.11.90.211:54334 -> 10.10.161.151:22
07/18-12:53:10.784025  [**] [1:1000002:1] SSH Connection Detected [**]
[Priority: 0] {TCP} 10.11.90.211:54334 -> 10.10.161.151:22
07/18-12:53:10.960866  [**] [1:1000002:1] SSH Connection Detected [**]
[Priority: 0] {TCP} 10.11.90.211:54334 -> 10.10.161.151:22
07/18-12:53:16.954348  [**] [1:1000001:1] Ping Detected [**] [Priority: 0] {ICMP} 10.11.90.211 -> 10.10.161.151
07/18-12:53:17.956812  [**] [1:1000001:1] Ping Detected [**] [Priority: 0] {ICMP} 10.11.90.211 -> 10.10.161.151
07/18-12:53:18.072226  [**] [1:1000001:1] Ping Detected [**] [Priority: 0] {ICMP} 10.11.90.211 -> 10.10.161.151
```

What is the sid of the rule that detects SSH? 1000002

